



Figure 1: Authentication protocols

authenticates other software systems. As shown in Figure 1, there are multiple protocols available for authentication, operating at different OSI layers, and each for a different purpose, in terms of strengthening security. Authentication can happen from Layer 3 to Layer 7. Given below are a few widely used high-level authentication types:

- **Log-on authentication:** This consists of a rudimentary combination of a user ID and password, as well as newer methods such as using Captcha images, biometrics, smart cards, PINs, etc.
- **Network authentication:** This operates at multiple OSI layers, and verifies the user's identity for network resources being accessed. Usually, the OS does this with the network driver and protocol stack. For example, once users authenticate and connect to a share, they are not asked for credentials again for that session.
- **IP authentication:** This operates at lower network layers and is primarily used to validate source and destination IP datagrams, by using IPSec or Kerberos security modules at its core, or in some cases, public key cryptography.
- **Remote authentication:** This is used for authentication between remote computer systems communicating for data transfers, typically virtual private networks (VPNs), which may use PAP or CHAP protocols.

On the Internet or the WWW, where HTTP is the main communication protocol, application and session layer security is paramount. Note that Web portals use a variety of authentication mechanisms. Some standard types that are widely in use are:

- **Basic authentication:** It uses Base64-encoded clear-text passwords; this is usually the default method for most Web servers.
- **Digest:** This is similar to the basic method, but passwords are encrypted using scrambling methods.
- **Form-based:** In this method, the HTTP protocol's POST command is used to submit data of an HTML form to the server; this can happen on a plain HTTP channel or a protected SSL channel.
- **NTLM:** This is a Microsoft proprietary protocol

operating at transport and session layers. It may be used by HTTP as a vehicle to perform authentication for Web portals. Its primary use is for authentication among Windows or non-Windows clients.

- **Client certificates:** While SSL is used to endorse the identity of a website-hosting server, the client certificate does the same for the user accessing that website. Typically, a client certificate is used as an economical means to replace expensive smart cards or SecureID tokens. Client certificates are implemented over the SSL or TLS protocols, and need browser support to participate in the challenge or response process.

Securing authentication

Authentication being crucial for securing software applications or systems, it has now become even more important to secure the authentication process itself. The repercussions of the successful penetration of an authentication system can be seriously harmful; attackers can gain access to sensitive information, and can delete, alter or corrupt valuable data. Further, the attacker can assume someone's identity, resulting in identity or monetary theft. If the compromised identity is of a network or server administrator, the damages are infinitely worse.

The authentication process we have discussed has three critical points at which the process is potentially vulnerable. When the user is typing the credentials, these could be stolen by a man-in-browser script or attack. When the credentials are being transmitted over the wire, they could be intercepted by an MITM attack. Third, when credentials are being compared with database entries, they could be altered to achieve a successful penetration. This shows that packet interception and crafting can be used to collect and manipulate information to make the authentication mechanism vulnerable. Let's discuss a few authentication attack types:

- **Bypass attacks:** An attacker's first wish is to bypass security; authentication is no exception. Usually, the root cause of an authentication bypass is either the software system's failure to impose access policies, or a weakly designed authentication system. For example, code that performs authentication using user credentials may enforce strict password policies, but might simply fail to disallow a blank password—creating a serious loophole. As another example, developers often mistakenly put protected and unprotected files in the same folder, making site code visible and vulnerable. Bypass attacks are usually tried against customised authentication systems, rather than robust industry-standard ones.
- **Brute force attacks:** Passwords are a single point of security failure even today. Besides mere guessing, attackers use scripts and customised software programs fed with all possible combinations against the authentication system. The combinations tried could include: all English words (a 'dictionary' attack); very